Vitalog — App Guide

Every feature, how it works underneath, and how we got here

Family health records · Flutter (iOS & Android) · Status as of 6 November 2026
Branch `family-health-architecture` · 72 Dart source files (~20,500 lines) · 33 test files, 169 automated tests · analyzer clean

Companion: **Vitalog User Manual** (how to use each screen, with screenshots). Sources this guide is built from: AGENTS.md, docs/HOW_IT_WORKS.md, docs/PENDING_TASKS.md, docs/SHARING.md, the security audit, the handoff notes, and the transcripts of all 15 Claude Code sessions on this project (26 Oct – 6 Nov 2026).

Contents

1. What Vitalog is
2. Product rules (non-negotiable)
3. The big picture
4. Screens and navigation
5. Adding a report: the reading pipeline
6. The parser and categories
7. Judging results: printed and usual ranges
8. Home dashboard, charts and trends
9. Editing, review and "wrong person"
10. Family members, photos, duplicates
11. Reminders
12. Display settings, Simple mode, themes, languages
13. Privacy and encryption on the phone
14. Accounts, Sync v2 and the recovery key
15. Family sharing and invites
16. Big screens: iPhone Duo and foldables
17. Design system and motion
18. Backend (Supabase)
19. Code map
20. Testing
21. Project history (all sessions)
22. Security work
23. Status, pending work and next steps
24. Feature ideas

1. What Vitalog is

Vitalog is a **private family health record for lab reports**. You pick a family member, add a lab report (camera photo, photo from the library, PDF, or almost any file), and the app reads it **on the phone**, pulls out every test (name, value, unit, reference range, high/low), files each test into a health group (Blood & CBC, Glucose, Kidney, Liver, Lipid, Thyroid, Vitamins, Iron, Urine and more), and shows it on a per-person timeline and dashboard. Over time it shows how each value changes.

It is **not** a medical provider: it never diagnoses, never invents a "health score", and only summarises what the lab printed.

> **The one-sentence promise:** reports are read on this phone and nothing leaves it unless you tap **Sync** — and even then the server only stores sealed (end-to-end encrypted) boxes it cannot read.

Who it is for

- A family member (often the adult child) who looks after the reports of parents, partner and children.
- Older people themselves — hence **Simple mode**, plain-language permission prompts, big buttons, and Telugu / Hindi.
- India-first: Indian lab formats (Thyrocare, SRL, Dr Lal PathLabs, Apollo, Metropolis), Indian number grouping (2,50,000), day-first dates, Indian reference sources.

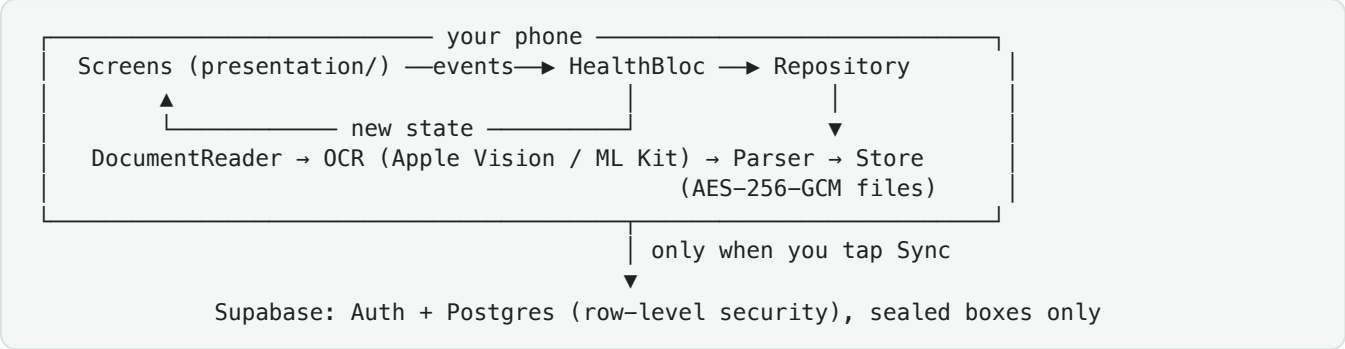
2. Product rules (non-negotiable)

Rule	What it means in practice
Offline-first / privacy	Health data never leaves the device except via explicit Sync. No analytics, crash reporters, cloud OCR or AI calls that see report content without the product owner's sign-off.
No manual data entry	Users never type results in. Anything the parser is unsure of is tagged *Needs review*; users may *correct* a value but never enter one from scratch.
No health score, no judging	Status comes from the printed H/L flag or the printed range. Built-in "usual ranges" are used only when nothing is printed, and labelled as such.
Status is never colour-only	Every high/low has a word and an icon as well as a colour.
No hard-coded strings / colours	Strings in `lib/l10n/app_en.arb`; colours from `context.colors` tokens (light + dark).
Motion	UI animations ≤ 250 ms, transform/opacity only, and everything honours the system "Reduce Motion".
Architecture	presentation → domain → data. Screens talk only to `HealthBloc`.
Never rename stored identifiers	The app was renamed from *Fammo*. Encryption tags `FAMM01/FAMM02`, Keychain entries `fammo.*` and the accent id `fammo` keep the old name so existing data still opens.

Key product decisions (with dates)

Date	Decision
2026-10-22	After Sync everything stays on the phone; Sync is a backup. Original documents never upload. The server sees only opaque profile ids.
2026-10-23	Sharing is end-to-end encrypted: equal access (no owner), "You" is per account, no email matching, invites are links with the secret in the `#fragment`.
2026-10-25	Restore has no button: signing in quietly pulls the account's data. Pushing still needs the Sync tap.
2026-10-26	The Face ID / fingerprint lock on original documents is the user's choice (opt-in), explained before any system prompt.
2026-11-03	Member names reach the server only sealed (Sync v2). Never send a member field outside a sealed box.
2026-11-06	`vitalog.app` is owned by someone else — a new invite domain must be bought before anyone outside the team creates an invite.

3. The big picture



- **Everything happens on the phone**: reading, sorting, judging high/low, charts. Works in airplane mode.
- **The server is an encrypted backup and the sharing channel**. It never sees original documents, names, test names, values or dates.
- **Layers**: *presentation* (screens, bloc), *domain* (plain entities and rules), *data* (reading files, OCR, parser, encryption, storage, sync). `family_health_dependencies.dart` is the composition root.

Technology

Area	Choice
App	Flutter / Dart, BLoC (flutter_bloc 9), clean architecture
OCR	iOS: Apple Vision + PDFKit (`ReportOcrPlugin` in AppDelegate.swift). Android: ML Kit text recognition (bundled Latin model) + PdfRenderer (MainActivity.kt). Both over the `vitalog/report_ocr` channel.
Storage	Encrypted JSON files in the app's documents folder; keys in Keychain / Keystore
Crypto	AES-256-GCM at rest; X25519 + HKDF + AES-GCM for sealed sync and sharing; Ed25519 for signed range tables
Backend	Supabase (Auth: email/password + native Google sign-in; Postgres with RLS; one edge function `delete-account`)
Notifications	flutter_local_notifications (phone-only reminders)
Links	app_links (invite links), share_plus
Languages	English, Telugu, Hindi (ARB files, `flutter gen-l10n`)

4. Screens and navigation

```
App start ─▶ Splash (logo draws itself; the coral dot beats while data loads)
          ─▶ first launch only: 3 welcome pages ─▶ sign-in offer ─▶ first-run tour
          ─▶ Dashboard: 4 tabs + floating bottom tray
               ├─ Home ........ greeting, At a glance, Needs attention, trends,
               │                latest report, categories, recent results
               ├─ Categories .. tested groups, then "Yet to test" / "When your doctor advises"
               │                └─ group ─▶ category results ─▶ test history (chart, Edit)
               ├─ Reports ..... timeline, Add (camera / photos / file), Sync
               │                └─ report ─▶ report dashboard (Home for that report only)
               └─ Family ...... members, add/edit/remove, share, account card,
                                reminders, settings, recovery key, open an invite link
```

The bottom tray (thumb zone)

"Read at the top, act at the bottom." One floating container holds the **dock row** — member switcher (always shows who you're viewing), Sync chip (on Reports), **Add a report** — and the **tabs**. The selected tab opens into a pill with its label over a sliding brand-coloured tile; the others show only their painted glyph. Each glyph plays a small moment when selected (the house draws a pulse, a tile becomes the dot, report lines scan in, the child hops). The dock hides on the Family tab.

Item actions

Long-press any item → bottom sheet of actions; a ⋯ button offers the same for discoverability. Menus are iOS-style pull-downs (`showPullDownMenu`); anything irreversible goes through an action-sheet (`showDestructiveSheet`) that says exactly what will be removed.

The 10-second rule

Shown the Home screen for 10 seconds, a stranger must be able to say "it's for family lab results". So the headline says what you're looking at ("Here's Maya's health snapshot"), the time greeting is the small line above, and empty screens show the health groups instead of a blank page.

5. Adding a report: the reading pipeline

```
ReportsScreen ──Add sheet──▶ camera / image_picker / file_picker
     │ UploadReport(path, name)
     ▼
HealthBloc ─▶ Repository.addReport
     │   LocalReportStore.keepOriginal  (encrypt with the vault key)
     │   save report (status: processing) ──▶ timeline shows "Reading…"
     ├─▶ processReport
     │     readOriginal (decrypt in memory — never written to disk in plain)
     │     DocumentReader: detect type from the BYTES
     │        PDF / image → native OCR (rows)      .docx/.xlsx/CSV/text/HTML → read in Dart
     │        .eml → attached PDF/photo or body    .doc/.xls/zip/binary → Unsupported
     │     LabReportParser (in Isolate.run, UI stays smooth)
     │     judge (printed flag → printed range → usual range) ; save (under a lock)
     ▼
HealthNotice (ready | needs review | failed | duplicate | other person) → snackbar with "View"
```

Status	When	User can
Reading…	While OCR + parsing run (the user keeps using the app; a scan-beam animation shows on the card)	Cancel (deletes the report)
Ready	Tests found, date found, every test has a usable range	Open it
Needs review	Report date not found, or any test without a usable range, or an unknown test needing a category	Edit / "Looks right" / pick a category
Failed	No tests found, OCR error, timed out after 90 s, or unsupported file	Try again (not for unsupported files)

Safety nets

- **Size caps**: huge files and zip bombs are refused (including zip entries that lie about their size).
- **Timeout**: reading stops after 90 seconds (*timed out*, Try again).
- **Vanished report**: if the user deletes/cancels while reading, nothing is saved.
- **Leftover copies**: temporary `scan-*.pdf` files left by a killed upload are swept on next start; Android cache copies are deleted after reading.
- **Duplicates**: the same file is caught on upload (file hash); the same paper report from another file is caught after reading (same member, printed date, lab, and every test with the same value). The copy is dropped and "View" opens the one kept. Undated reports are never called duplicates.
- **Wrong person**: the parser reads the printed patient name (kept on the phone only). If it doesn't match the member's first name, the timeline offers *Keep here* / *Move to…*.

6. The parser and categories

`LabReportParser` is rule-based (no AI). Input: one string per printed row, columns joined by two spaces.

- A row is a test if its start matches a **catalog alias** (~300 spellings in `lab_test_catalog.dart`, matched in one pass with an `AliasTrie`; longest wins).
- Unknown tests are accepted only under a recognised section heading *and* with value + unit + range. A complete row the catalog doesn't know and that isn't under a known heading goes to **Other** as *Needs review*; the user files it once and the choice is remembered (encrypted) for later reports.
- Values must be standalone numbers (so "25-OH" or "T3" aren't values). Indian grouping `2,50,000` is supported.
- Status: printed H/L flag wins; otherwise value vs. printed range. Ranges printed per sex ("M: 13–17 F: 12–15.5") are judged with the member's sex.
- Dates are day-first (India/UK) unless impossible; date-of-birth lines are ignored. Report date, collection date and upload date are kept separate — upload date is never used as a medical date.
- Lab name is cut at the first address/contact marker; unknown test names lose phones, emails and links (`Redactor`).
- OCR quirks handled: Cyrillic-misread units → catalog's typical unit; `HIU/mL` → `µIU/mL`.

Categories (predefined, 17 groups)

Defined in `domain/health_categories.dart`, each with its **key tests**. The Categories tab shows **Tested** groups (with "Not yet: …" listing missing key tests) and then greyed **Yet to test** groups. "On advice" groups — pancreas, cancer markers, hormones, infections, clotting — list example tests under "When your doctor advises" and are never flagged as missing. Key tests only point out what's missing; they never judge results. A test can belong to more than one group.

7. Judging results: printed and usual ranges

1. **The printed range always wins** (and a printed H/L flag wins over everything).
2. If **no range is printed**, the repository tries a built-in **usual range** (`domain/reference/`, compiled as constants; sources: WHO, Indian, ADA/RSSDI, ATP III, KDIGO; the only source document is `docs/REFERENCE_RANGES.md`).
3. A usual range is applied only when **unit, sex and age band are all known** — it never guesses. Adult ranges are skipped for under-18s (except the WHO haemoglobin cut-off).
4. Results judged this way show *usual range* wording and the source — never "per report". This judgement stays on the phone and is never synced.

Future range updates from a server must pass `verifyRangeTable`: an Ed25519 signature check with the public key shipped in the app, and no downgrade to older editions. The private signing seed lives in the original Mac's Keychain.

> Open: the built-in ranges need a clinician's sign-off before launch; pediatric ranges need clinical sources.

8. Home dashboard, charts and trends

Home order: greeting → **At a glance** / **Needs attention** → **trends** → latest report → categories → recent results.

- **At a glance**: hero count of latest results within range, a stacked status bar, and a legend with icon + word + count (never colour-only).
- **Needs attention**: latest high/low results. No confetti when anything needs attention.
- **Trend tiles**: latest value, change since previous, a sparkline drawn over the printed-range band; tap → the test's history. After 3 moves the same way a tile says "Up 3 times in a row" / "Down…" — it states what happened, never what it means. Readings in different units are never mixed.
- **Category tiles**: count each test's latest high/low as "N outside range".
- **Test history**: every dated value, a chart of same-unit readings over the range band, Edit at the bottom.
- Chart colours are dedicated `chart*` tokens validated for colour-blind distinguishability in both themes.
- Pure helpers (`latestPerTest`, `StatusTally`, `trendsFor`, `trendStreak`, `parseRange`) are unit-tested.
- Trends are hidden in Simple mode and on a single report's dashboard. Home sections can be hidden in settings; hidden sections aren't built at all.

Tapping a report on the timeline opens the **report dashboard**: the same Home screen narrowed to that report's results (always shows every section, updates live while reading).

9. Editing, review and "wrong person"

- **Edit** (test detail → bottom bar): fix value, unit, range or category. `updateResult` re-judges the status, marks the result *edited*, and flips a *Needs review* report to *Ready* once nothing is left to review.
- **Looks right**: confirms a flagged result without changing it.
- **Compare with original**: shows the original document next to the value — decrypted in memory only.
- **Category picker**: files an unknown test; remembered by lowercased test name for future reports.
- **Move to…**: moves a report to another member (`assignReport`), re-judging usual ranges for the new person's sex/age.

10. Family members, photos, duplicates

- **Add** (Family tab or the member switcher): name, relation (stored as a fixed key so it translates), age (stored as a birth year so it stays current), sex (or Not set); photo via Edit details. Saved encrypted in `members.json`.
- **Edit details**: long-press on the Family tab; re-judges usual ranges.
- **Remove**: if the member has reports, one confirmation names how many go; removes reports, results, originals, photo and (when signed in) their server rows. For a *shared* member, removing means leaving — shared reports stay for the others.
- **Photos**: `photos/<id>.bin`, encrypted, never in members.json or anything synced.
- **Switching**: from the dock keeps the current tab; from the Family list goes to Home.
- Real installs start **empty** (no sample family). The sample family (Maya, Arjun, Anika, Meera) exists only in tests and the manual's screenshots.

11. Reminders

`lib/features/reminders/` : phone-only scheduled notifications (e.g. "Next thyroid test"). Stored encrypted in `reminders.json`. `RemindersCubit` schedules the next 4 occurrences per reminder and re-syncs on start and whenever members change (a removed member's reminders go). Entry points: the bell on Home (with a dot when one is due within 7 days) and the Family tab.

Privacy on the lock screen: only the user's own title and "Reminder for {name}" — never test names or values. Before Android's permission prompt the app explains why; after a refusal it offers *Open Settings*.

Not built: reminders that reach other family members' phones (needs sharing to be live).

12. Display settings, Simple mode, themes, languages

Saved in a plain `settings.json` (not health data) via `SettingsCubit`.

Setting	Effect
Simple mode	Text ≥ 1.3×, bold text, darker greys, 56 px buttons and bigger icons, a big "Add a report" button, categories grid hidden, plain status words ("Higher than range"), numbers without count-up, notices stay 10 s, trends hidden.
Home sections	Show/hide: At a glance, trends, latest report, categories, recent results, range note.
Theme	System / Light / Dark.
Accent	Vitalog, Ocean, Plum, Ember, Graphite — re-hues brand colours and near-grey neutrals (hue only, so contrast holds). Status colours and the logo never change.
Language	System, English, తెలుగు, हिन्दी. All strings are translated (drafts awaiting native-speaker review: `docs/translations_review.csv`).
Lock originals	Face ID / fingerprint / screen-lock PIN before showing an original document (see §13).

13. Privacy and encryption on the phone

What	How it's protected
reports.json, members.json, category choices, reminders, photos	AES-256-GCM, tag `FAMM01`; key in Keychain (iOS) / Keystore (Android), this device only, no prompt. Old plaintext files are migrated automatically.
Original documents	AES-256-GCM with the separate **vault** key, tag `FAMM02`. Opt-in lock: iOS Keychain `userPresence` (Face ID / passcode); Android 11+ Keystore key needing fingerprint/face or screen-lock PIN per use (not invalidated by enrolling a new fingerprint). Re-locks after 2 minutes away.
Decrypted content	Only ever in memory (OCR and "Compare with original").
App switcher	A brand-coloured cover hides health data in Recents (iOS native cover; Android 13+ no thumbnail, older uses FLAG_SECURE).
Backups	Android backup and device-to-device transfer exclude app data.
Recovery key copy	Clipboard is cleared 60 s after Copy.
Permission prompts	Plain explanation before every system prompt (camera, photos, Face ID, notifications), written for older users; Open Settings after a refusal.

Before the first report the app explains the originals lock and only "Turn on" leads to a system prompt; a toggle on the Family tab changes it later.

14. Accounts, Sync v2 and the recovery key

Sign-in

Optional. Email/password (confirmation email, reset) or native Google sign-in (`google_sign_in` → `signInWithIdToken`). Builds without the Supabase `--dart-define`s run fully offline and say "Cloud sync isn't set up in this build yet."

Sync v2 (sealed)

1. Every family profile has its own random AES-256 **profile key**.
2. Each report (with its results) and each member is **sealed** with that key on the phone.
3. Profile keys are **wrapped** for the account's X25519 public key.
4. Server tables: `account_keys`, `profile_keys`, `sealed_profiles`, `sealed_reports`. The server sees opaque ids, sizes and timestamps — never names, lab, file names, test names, values, ranges or dates.
5. Data stays on the phone after Sync. Originals never upload.
6. Deleting a report or member deletes its server rows (real deletes). **Delete account** (Family tab) removes everything via the `delete-account` edge function.

The account key and recovery key

The account's private key lives in the Keychain (iOS: synchronizable → iCloud Keychain, so a new iPhone gets it) plus a **recovery key** shown once after the first Sync ("Save to my passwords" or Copy; again from the Family tab). A phone without the key asks "Enter your recovery key". The account key is never replaced — that would orphan every sealed row.

Restore

No button: signing in quietly pulls and merges the account's reports, results and members. Nothing is uploaded until the user taps Sync.

> Status: built and unit-tested, but the Supabase projects (staging, prod) haven't had `schema.sql` + `hardening.sql` applied yet, so Sync, restore and invites have not been tried end to end.

15. Family sharing and invites

- **Equal access**: no owner. Anyone with access can add reports, remove someone, or leave.
- **Invite**: long-press a member → Share → family card → *Invite someone*. The app syncs that member, then opens the share sheet with `https://<invite host>/i/<id>#<secret>`. The secret is in the `#fragment`, which browsers never send to a server.
- **Claim**: the link opens the app (app_links), or the user pastes it via Family → *Open an invite link*. The claim screen shows a preview (sealed with the link's secret), asks "Who is X to you?", and on accept pulls the profile and its reports and opens Home on them. Single use, expiry, rate limit enforced by the server (`open_invite`).
- **Combine**: accepting as "You" when the phone already has a "You" offers Combine / Keep separate; combine moves reports across, drops a file already present, keeps your own name/sex/birth year/photo/reminders.
- **Family card**: who has access (with the name each person goes by), pending invites with Cancel, Remove.

> **Launch blockers:** buy a new invite domain (vitalog.app is taken — `docs/INVITE_DOMAIN.md`), host `invite_site/`, verified App Links + iOS Associated Domains (paid Apple team), then remove the `com.vitalog.app://` hand-over button. Not built: key rotation after removal, notifications to others on remove/combine.

16. Big screens: iPhone Duo and foldables

- **Side layout** when width ≥ 700 and wider than tall. Upright and folded keep the phone layout.
- **Side tray**: the bottom tray stood on its side on the **left** edge (product owner's call over Apple's right-side default): person on top, vertical tabs, Sync on Reports, Add report at the bottom. Content keeps clear of the Duo's right-hand status column.
- **Two panes** split at the fold: Home = status | history; Categories = groups | results; Reports = timeline | report; Family = people | settings. Navigation opens into the right pane.
- Tablets (> 736 pt) use a centred 640 pt reading column.

17. Design system and motion

- **Logo = splash = launcher icon**: a pulse trace forming a "V" over ruled log lines, ending in a coral "latest reading" dot. The splash slides the lines in, draws the trace, pops the dot and beats it (~67 bpm) as the loader, then lifts away. Brand colour `#173D35`.
- **Shapes**: Apple-style continuous corners (`AppRadius` 8 / 12 / 16 / 20 / 26 / 30, superellipse). Nested shapes are concentric (inner = outer − gap).
- **Colours**: `AppColors` tokens for light and dark, accents, a coral `reading` token, dedicated chart tokens.
- **Motion primitives**: `Reveal` (staggered entry), `CountUpText`, `ScanBeam` (report being read), `celebrate()` (confetti + haptic when a report is ready and nothing needs attention), `PressScale`/`TapCard` (press feedback with a haptic tick). All honour Reduce Motion.
- **Empty states**: illustrations that assemble and idle like the onboarding pictures (~20 s, then rest), centred, with the health groups shown so the app explains itself.
- **Onboarding**: 3 welcome pages whose illustrations assemble with the swipe, then the sign-in offer ("Not now" skips it), then a spotlight tour (replay: "Take a quick tour").

18. Backend (Supabase)

Piece	Detail
Projects	**staging** and **prod**. Keys in git-ignored `supabase.staging.local.json` / `supabase.prod.local.json`, passed with `--dart-define-from-file`. Only the URL + publishable key go in the app; never the service-role key.
Schema	`supabase/schema.sql` (sealed Sync v2 tables, invites, RLS via `has_profile`, functions `open_invite`, `may_take_profile`, `drop_orphan_profile`) then `hardening.sql`. Every function has `set search_path = ''`.
Edge function	`delete-account` (uses the service-role key on the server only).
Auth	Email (confirm), Google (both client ids, "Skip nonce check"), redirect `com.vitalog.app://login-callback`. Prod adds CAPTCHA, redirect allow-list, backups (`supabase/PROD_SETUP.md`).
Setup guides	`docs/plans/2026-11-04-supabase-sync-v2-setup.md` (staging), `supabase/PROD_SETUP.md` (prod).

```
# Run offline (no account features)
flutter run -d "iPhone 16 Plus"
# Run with staging sync
flutter run --dart-define-from-file=supabase.staging.local.json
```

19. Code map

Path	Role
`lib/main.dart`	App root: theme, l10n, BlocProviders, Backend.init, splash → onboarding → dashboard, invite-link listener
`lib/core/`	backend (Supabase + auth), brand (logo, splash), layout (readable width, insets), settings (SettingsCubit), theme (AppColors, AppShape)
`lib/features/onboarding/`	Welcome pages, OnboardingGate
`lib/features/auth/`	Sign-in screen (Google, email sign in / up / reset)
`lib/features/reminders/`	Reminder model, scheduler, cubit, screen
`family_health/domain/`	Entities (FamilyMember, HealthReport, LabResult, HealthCategory, FamilyHealthSnapshot, sharing), predefined categories, reference ranges, repository contract
`family_health/data/extraction/`	DocumentReader, ReportTextRecognizer (native channel), LabReportParser, lab_test_catalog, AliasTrie
`family_health/data/local/`	LocalReportStore (encrypted files), ReportCipher (FAMMO1/FAMMO2), vault keys
`family_health/data/privacy/`	Redactor
`family_health/data/sync/`	ReportSyncService (sealed v2), account_key (X25519, recovery key)
`family_health/data/sharing/`	sharing_crypto (profile keys, wrapping, invite links, claim tokens)
`family_health/data/repositories/`	FamilyHealthRepositoryImpl — the heart: composes everything, write lock, usual-range judging, learned categories, sync, sharing
`presentation/bloc/`	HealthBloc, events, state, HealthNotice (one-off snackbars)
`presentation/pages/`	dash_board (tabs, tray, notices), home, health_subscreens (categories, results, test detail), reports, report_dashboard, profile (Family tab), claim_invite, empty_family_experience (tour), navigation
`presentation/widgets/`	health_widgets, health_charts, motion, edit_result_sheet, add_member_sheet, display_settings, apple_menus, vitalog_nav_bar, side_layout, share_profile_sheet, recovery_key_sheets, permission_help, empty_art, header_wash
`ios/Runner/AppDelegate.swift`	Vision OCR + PDFKit, document camera, privacy cover, UIScene setup
`android/.../MainActivity.kt`	ML Kit OCR, PdfRenderer, document scanner, VaultKey (biometric Keystore), recents cover
`supabase/`, `invite_site/`	SQL, edge function, prod guide; invite web page + app-link files

20. Testing

```
flutter analyze        # must say "No issues found"
flutter test -j 2      # 169 tests pass (widget tests are timing-sensitive at full concurrency)
```

Area	Tests
Parser	test/extraction/ — incl. a regression case from real Vision output, sex-banded ranges, document reader (zip bombs, forged sizes)
Privacy & crypto	test/privacy/ — redaction, sealed sync (no member field outside a box), sharing crypto, leftover copies
Ranges	reference_ranges_test (signature, downgrade)
Bloc & store	health_bloc_test (upload → read → notice; failure; sync gating), report_store_test, report_sync_restore_test
Screens	widget_test (tour, profile switch, upload → timeline → report dashboard, sideways layout), category card semantics, health_charts_test
Manual screenshots	integration_test/manual_screenshots_test.dart (regenerates the User Manual's pictures)

Manual test plans: `docs/TEST_PLAN.md`, `docs/TEST_USER_RUNBOOK.md`.

21. Project history (all sessions)

Reconstructed from git history and all Claude Code session transcripts. Before 26 Oct the app was built and committed in five commits; from 26 Oct several sessions ran in parallel on the same folder.

Date	What happened
22 Oct	Mock family-health architecture, then the first real build of Vitalog (on-device OCR on iOS, parser, timeline, report dashboard, Supabase sync v1). Decision: Sync is a backup; originals never upload.
23 Oct	"Complete Vitalog experience": categories, edit, usual ranges, charts, Simple mode, themes, onboarding. Sharing designed as end-to-end encrypted (SHARING.md). Supabase project created.
25 Oct	Real Android port (ML Kit OCR, PdfRenderer). Server-side deletes, account lifecycle (delete account), auto-restore on sign-in, Keychain hardening.
26 Oct	**Security audit** (14 findings, S1–S14); fixed S1 (Android cache copies), S3 (vault re-lock), S9 (size caps), S12–S14 (Android biometric vault, opt-in lock). Ran on the Android phone. Empty states redesigned like onboarding; "Move to another member" for wrong-person reports; welcoming tour for signed-out users; Doherty-threshold check; **iPhone Duo / sideways layout** with left side tray and two panes; alignment fixes across screens.
27 Oct	"10-second home screen" review and redesign plan; frosted/greener light-theme background; Duo full-width fix; members, duplicates and reminders features; design skills installed (unslop, stageshow, better-interface, find-animation-opportunities).
2 Nov	**Tab bar restyle**: sliding tile, label pill, painted animated glyphs in brand colours (run on the Duo simulator); empty-state animations restored.
3 Nov	**Sync v2 (sealed)**, account key + recovery key, member names sealed (S4/S5); app-switcher cover (S2), release signing (S7), backup exclusions (S8), pinned supabase-js (S10), SQL search_path (S11). Plain-language permission prompts for older users. Ten small bugs fixed. Cross-session status reports.
4 Nov	**Invite family**: share links, claim screen, family card, shared ids, app links; expert/tester cross-check. Smaller items: zip-size check, sex-banded ranges, package upgrades, range-signing key, accessibility pass, **Hindi**. Staging/prod Supabase setup plan written. Handoff file + zip for another Mac.
6 Nov	Pulled from GitHub (srikanth-7/vitalog). Security review of sharing (box/row binding, re-entry window, invite lockout). **Combine "You" profiles**. Clipboard clear for recovery key, leftover-scan sweep, CategoryCard screen-reader order, **trend notes**. Telugu/Hindi completed (review CSV). Cleanup (#26) + prod setup guide. Invite-domain guide (vitalog.app found to be taken). Feature ideas doc. This guide and the user manual.

22. Security work

#	Finding (2026-10-26 audit)	Status
S1	Readable report copies in Android cache	**Fixed, phone check pending**
S2	App-switcher snapshot shows results	**Fixed, phone check pending**
S3	Vault never re-locks	**Fixed (2 min away)**
S4	Member names synced	**Fixed — only sealed**
S5	Sync v1 plaintext on server	**Sealed Sync v2 built; server setup pending**
S6	Dashboard password exposed in chat; gates open	**Owner: change password, 2FA, CAPTCHA**
S7	Release build falls back to debug key	**Fixed**
S8	Android device transfer copies data	**Fixed**
S9	No input size cap	**Fixed**
S10/S11	Unpinned supabase-js; SQL search_path	**Fixed**
S12/S13	supabase.json not ignored; extension parsing	**Fixed**
S14	No Android biometric lock on originals	**Fixed, phone check pending**

2026-11-06 review (sharing): report boxes must match their row's profile and results their report; closed a 10-minute re-entry window after removal; dropped a per-invite lockout anyone could trigger. Open: own the invite domain; replace the custom-scheme hand-over with verified links; bind the invite's wrapped key to its profile id; rotate profile keys after removal.

Threat model: `docs/THREAT_MODEL.md` (stolen device, rooted phone, curious apps, network, server staff, accidental pairing, enumeration, supply chain, telemetry creep).

23. Status, pending work and next steps

Needs the product owner (unblocks the most)

1. Apply `schema.sql` + `hardening.sql` on **staging**, then prod (Sync, restore and invites can't be tested until then).
2. Plug the Android phone back in — nothing since 2 Nov has been tried on a phone (phone checklist in PENDING_TASKS.md).
3. S6: change the Supabase dashboard password, turn on two-factor.
4. Buy the invite domain; Google sign-in config (client ids, Android SHA-1); final bundle id and signing; privacy policy and store disclosures; clinician review of built-in ranges; native-speaker review of Telugu/Hindi.

Launch blockers

- Server set up and Sync/restore/invites tested end to end.
- Tested on 20–50 real reports from the top labs.
- Final bundle id, signing, store disclosures (DPDP Act, medical disclaimer, App Privacy, Play Data safety).
- Invite domain + verified links.
- Clinical review of reference ranges.

Engineering backlog

- Android document scanner dependency (blocked by office network); Flutter SDK upgrade (same).
- Pediatric and age-banded ranges; non-English reports.
- Local store → SQLite only if saves get slow (deliberately deferred).
- Sharing: key rotation after removal, notifications, edits by others.
- VoiceOver / TalkBack pass on a real phone.

24. Feature ideas (2026-11-06)

#	Idea	Value	Effort
1	Open in Vitalog — receive a report from WhatsApp/email via the share sheet	Very high	2–4 days
2	Doctor summary PDF	Very high	2–4 days
3	Same test across units (mg/dL ↔ mmol/L)	High	~1 day + clinical check
4	Retest reminder suggestion	Medium	~1 day
5	"What is this test?" (reviewed text)	Medium	2–4 days
6	Factual trend notes	Medium	**Built 6 Nov**
7	Home screen widget	Low–medium	2–4 days
8	Apple Health / Google Fit import	Medium	a week+

Not recommended: medication/condition lists and emergency cards (manual entry), AI chat or summaries (would send report content off the phone), a health score.